

Защита от админа: правильно управляем ПОЛИТИКАМИ

● Максим Киселев

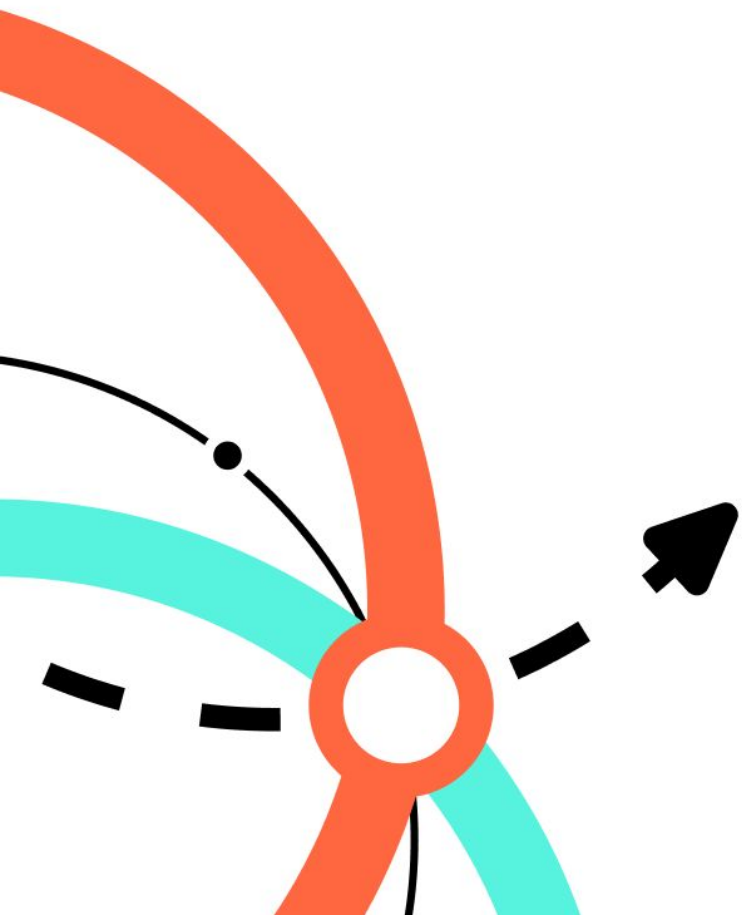
Руководитель разработки
Deckhouse Stronghold



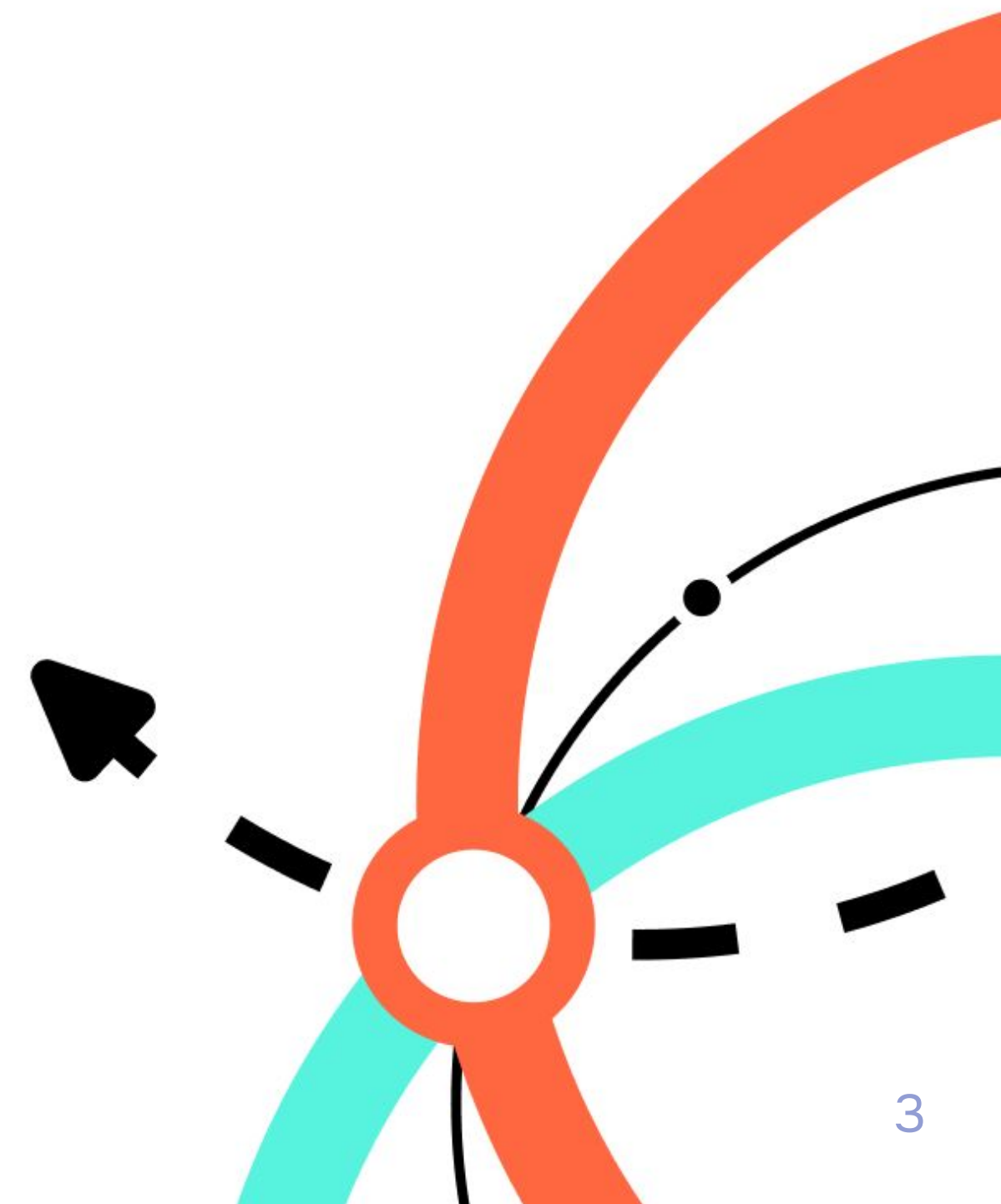
Конфигурация Vault

Типичные способы
конфигурации ролей и политик
для Vault-подобных систем

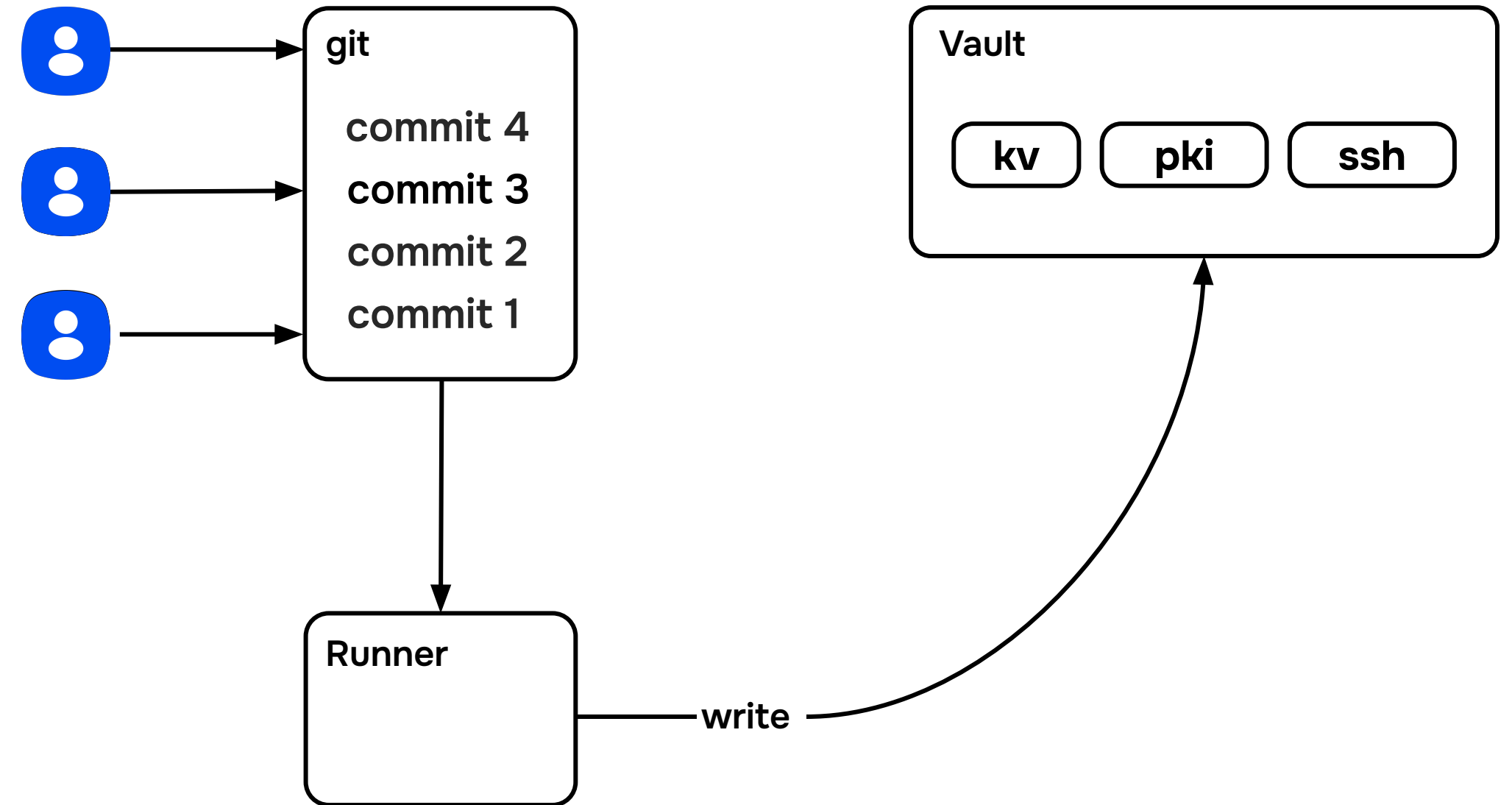
1. Ручное управление
2. Автоматизация через API
3. Декларативное управление с ручным применением
4. Декларативное управление с применением через CI



Если мы хотим изменять конфигурацию
доступа — нам требуется иметь
привилегированный токен
вне защищённого Vault

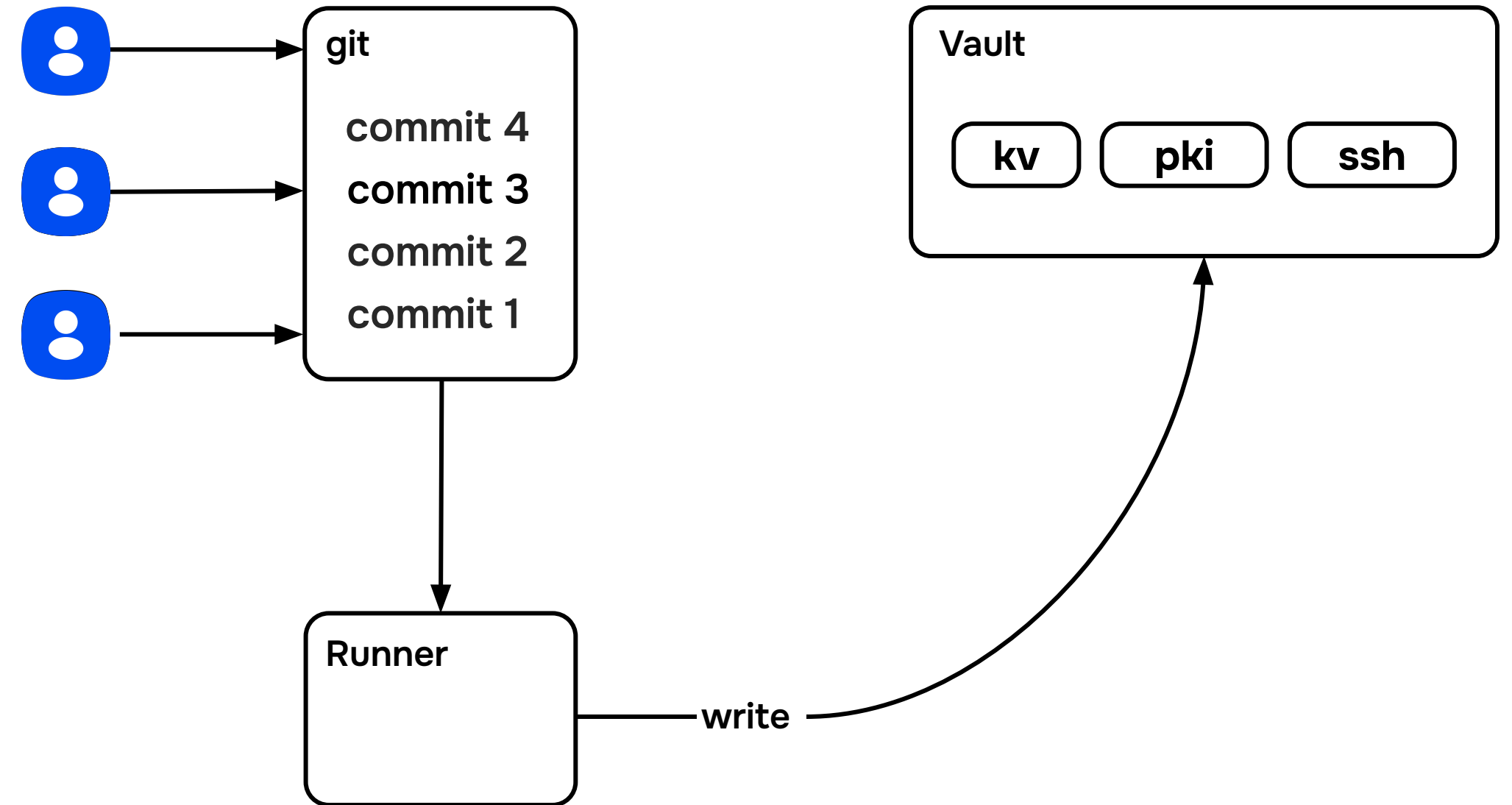


CI/CD — мнимая безопасность



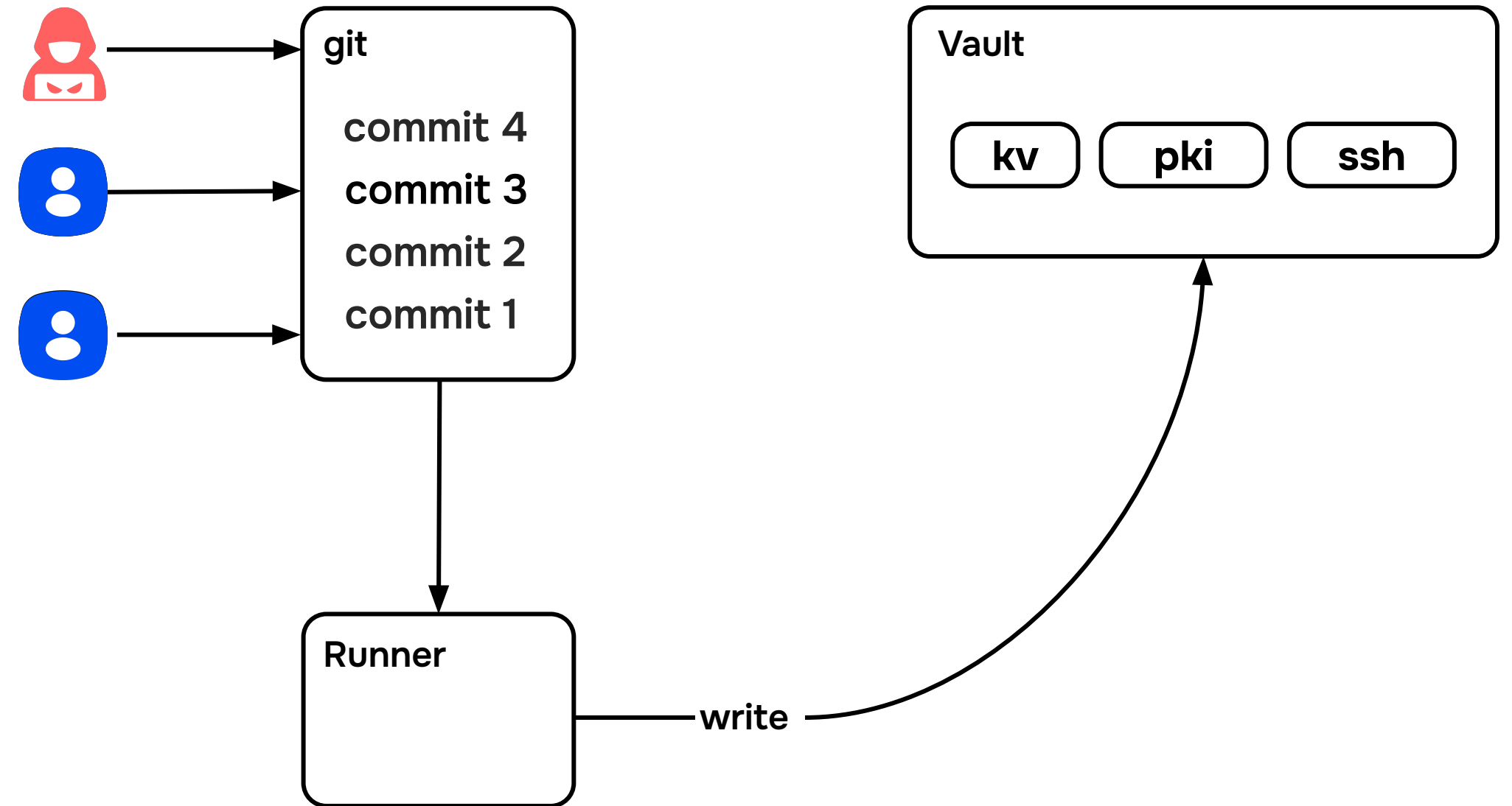
CI/CD — мнимая безопасность

→ Ожидания



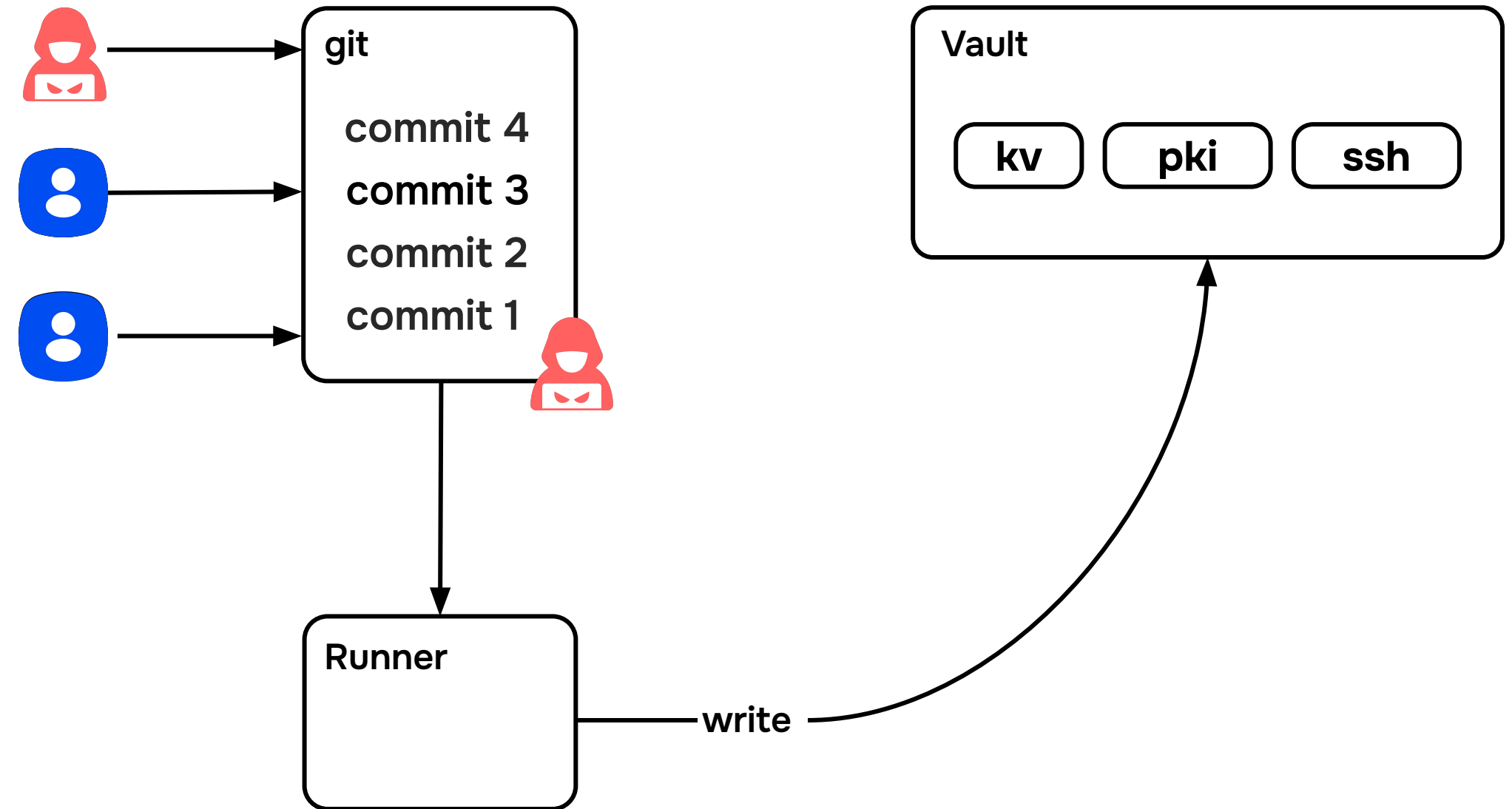
CI/CD — мнимая безопасность

- Ожидания
- Пользователь
скомпрометирован



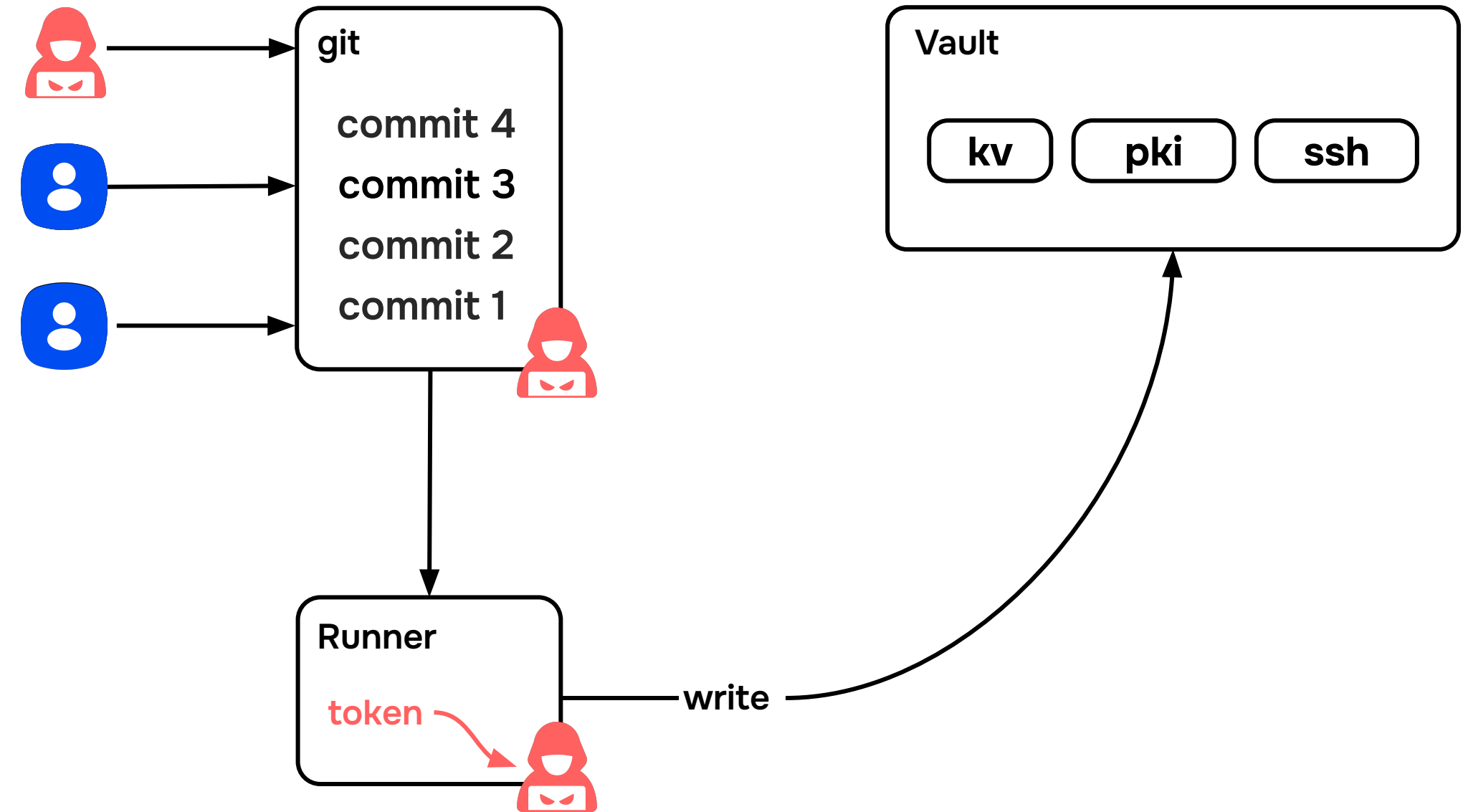
CI/CD — мнимая безопасность

- Ожидания
- Пользователь скомпрометирован
- Репозиторий скомпрометирован



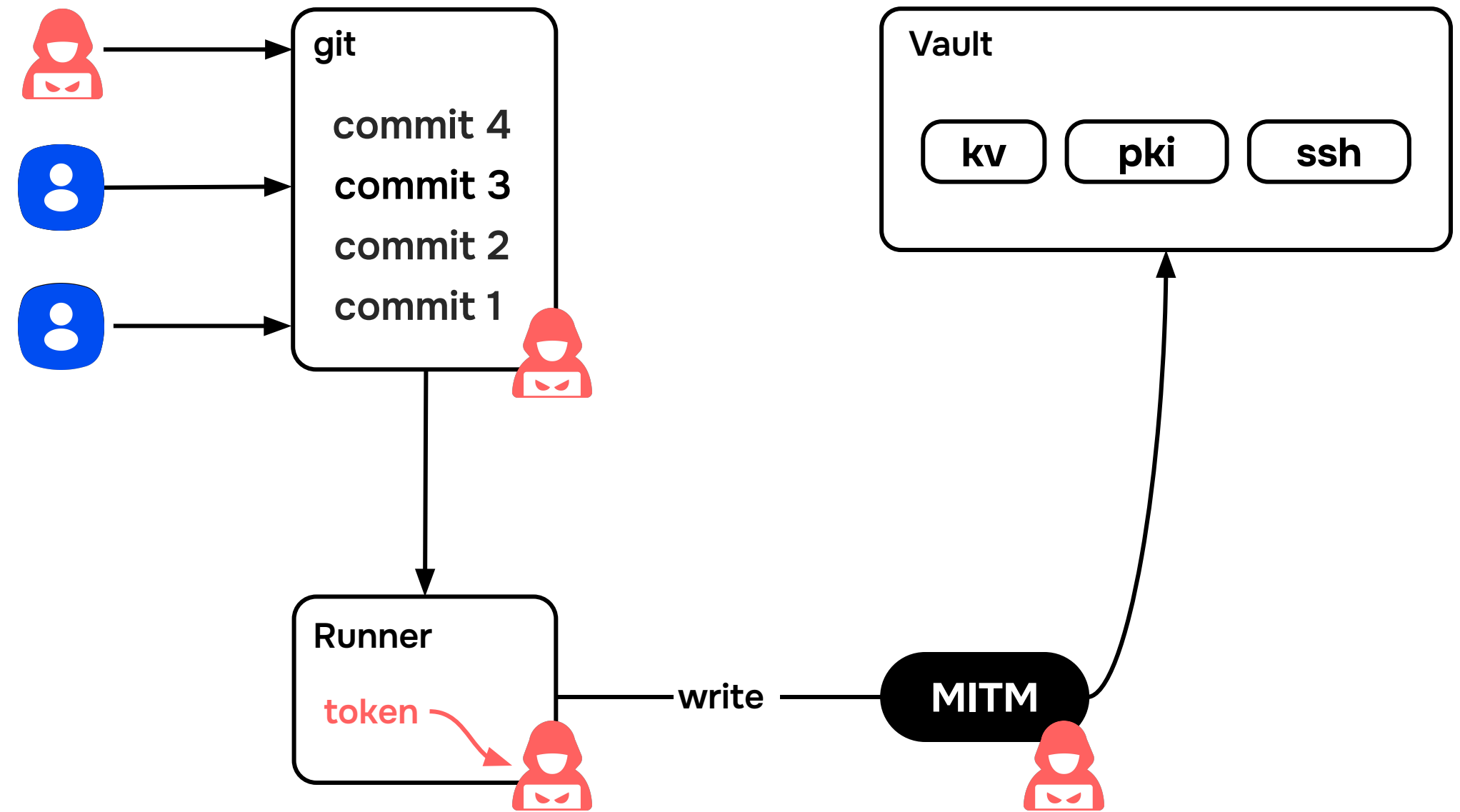
CI/CD — мнимая безопасность

- Ожидания
- Пользователь скомпрометирован
- Репозиторий скомпрометирован
- Раннер скомпрометирован

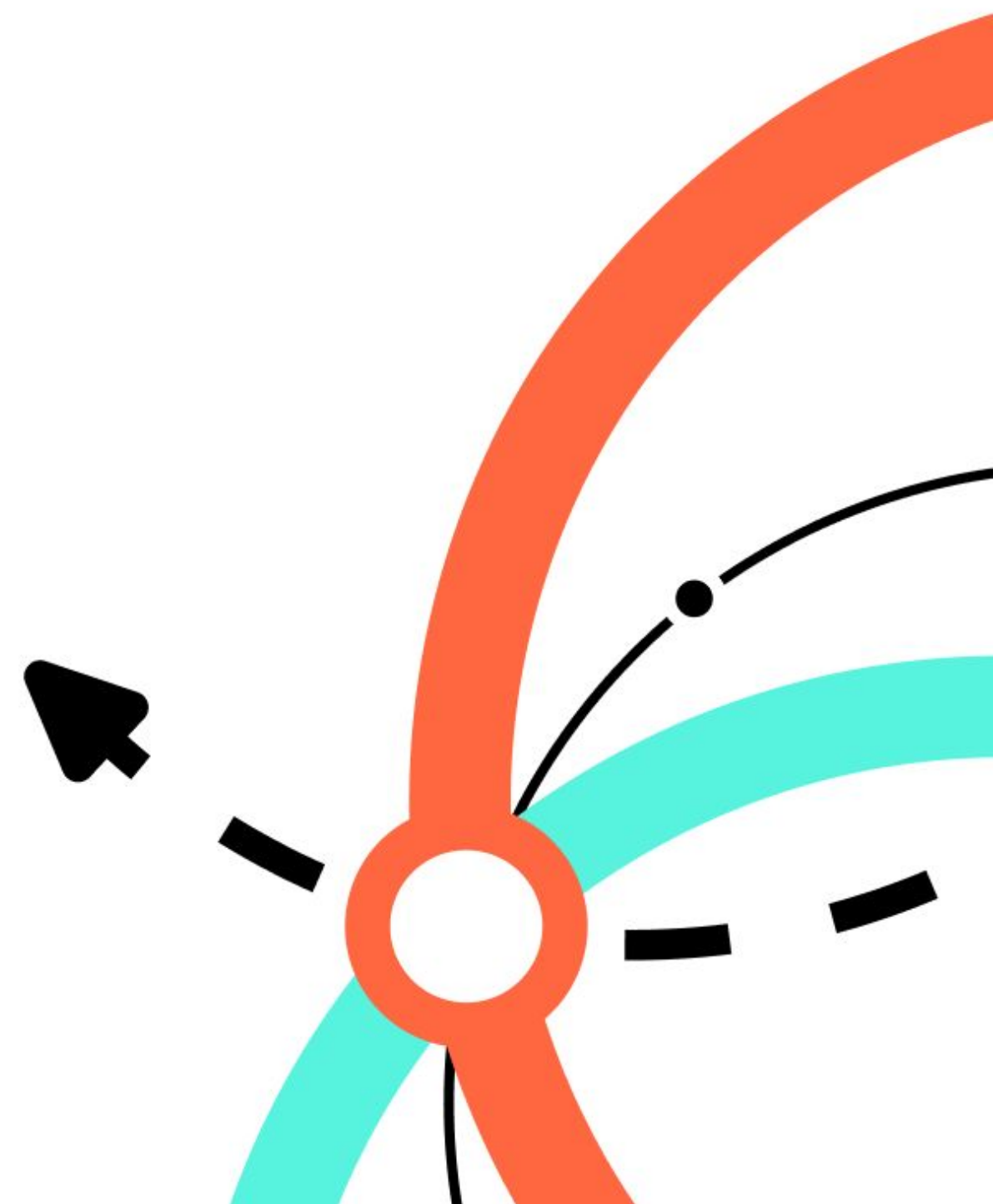


CI/CD — мнимая безопасность

- Ожидания
- Пользователь скомпрометирован
- Репозиторий скомпрометирован
- Раннер скомпрометирован
- Атака MITM при передаче данных

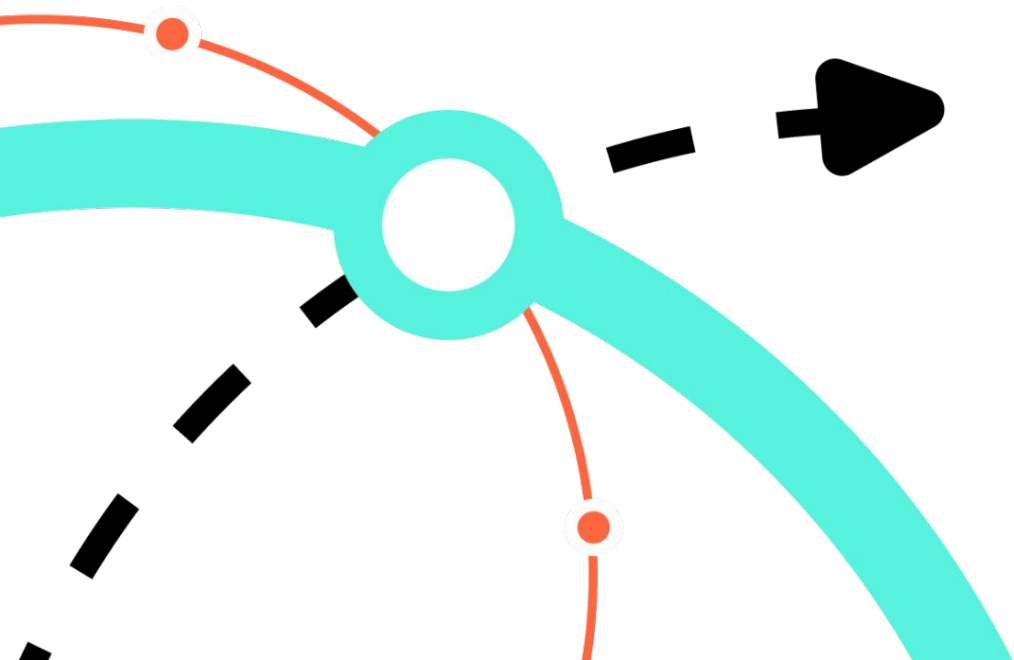
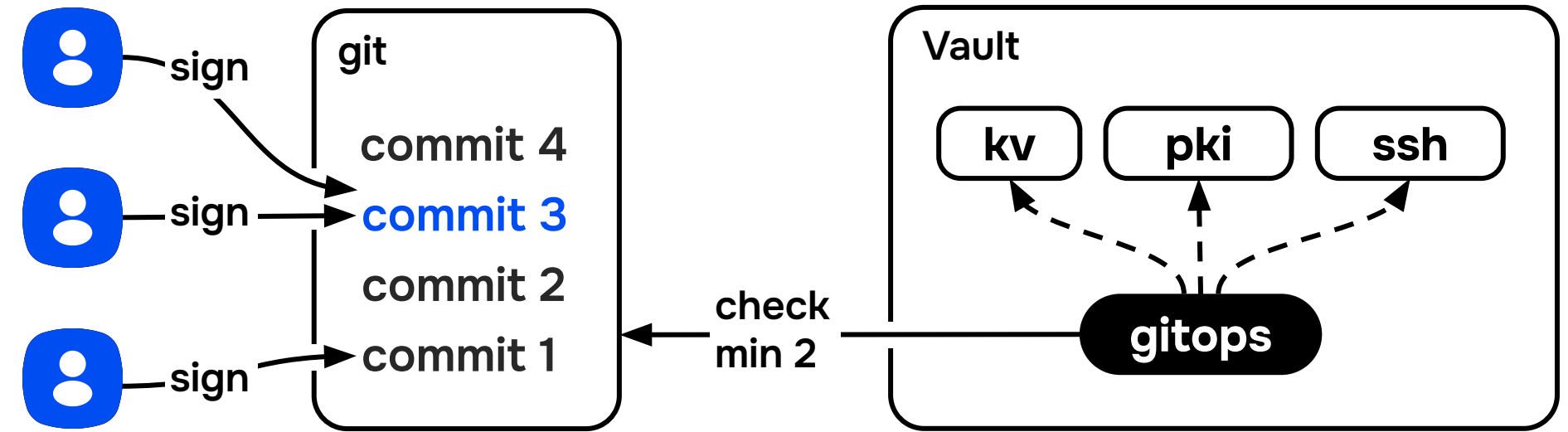


Снаружи не должно быть
привилегированных токенов,
а значит, конфигурация не должна
настраиваться снаружи



Кворум подписей

Проверяем Git-репозиторий
и приводим конфигурацию
в соответствие при наличии
кворума подписей

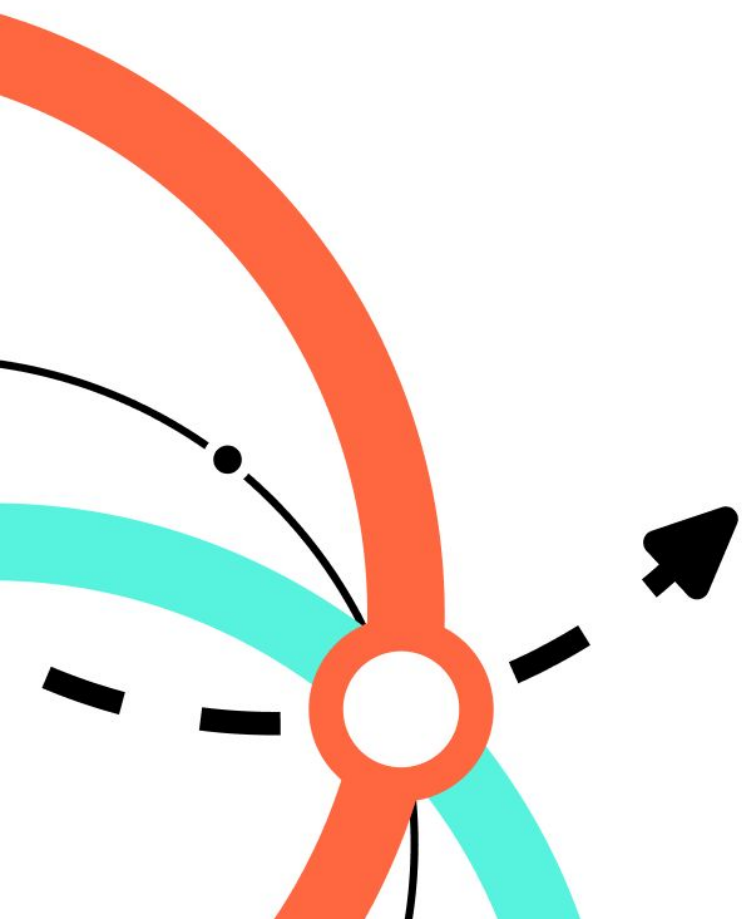


Мастер-ключа **не существует**
вне процесса ОС, компрометация
извне невозможна

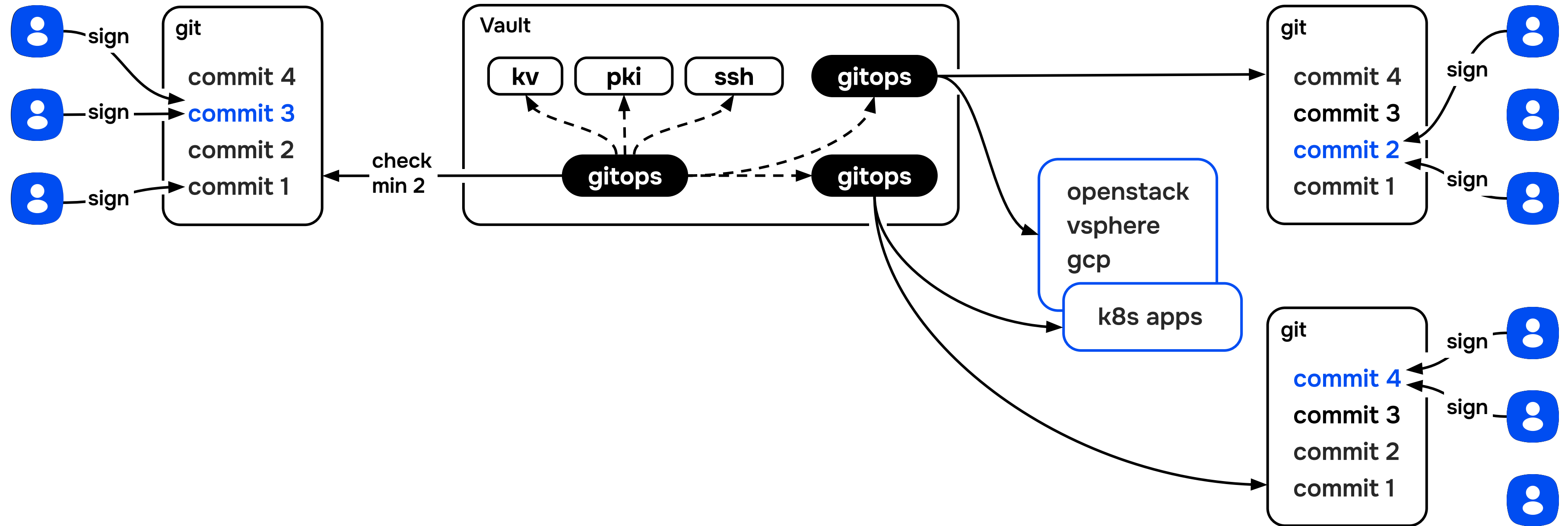


Преимущества механизма секретов GitOps

- Привычное декларативное управление
- Аудит
- Потеря одного или нескольких ключей не блокирует доступ к системе
- Компрометация одного или нескольких ключей не приводит к компрометации системы
- Невозможно подменить конфигурацию



Используем GitOps вместе с Terraform



Управляйте конфигурацией безопасно

Формат конфигурации:
YAML, Terraform (OpenTofu)

- ✓ Доступно в Deckhouse Stronghold
- ✓ Доступно в Open Source



Где взять: [🔗](#)



Подробнее

Спасибо за внимание!

📧 @trublast

📧 @deckhouse_news

🐙 github.com/deckhouse